

CYB 260 Module One Worksheet

Law	Briefly describe the law.	Whose rights are covered by the law?	Who in an organization is responsible for ensuring compliance with the law?
Family Educational Rights and Privacy Act (FERPA)	A law that protects student records (for current and former students) in institutions that receive funds from the U.S. Department of Education. It covers all aspects of personally identifiable information (PII) for students within the institution.	Any individual who is or has been enrolled at an educational institution.	The administration that governs student PII (bursar's or financial aid office).
Computer Security Act	A law designed to protect the public's sensitive data when that data is stored or processed on federal government computer systems.	The Act doesn't directly protect private entities' personal computers, but by strengthening federal cybersecurity practices, it indirectly benefits the public. It focuses on sensitive but unclassified information. This can include: Social Security numbers, medical records, personnel files, financial records, internal government communications, legal or investigatory records, and any other data that could compromise privacy, operations, or safety if improperly accessed or altered.	Any federal agency operating a system that processes "sensitive but unclassified" information is required to comply. This includes both civilian and defense-related agencies. Contractors and third-party vendors working with these agencies can also be affected if they handle the agency's data or operate its systems.

Law	Briefly describe the law.	Whose rights are covered by the law?	Who in an organization is responsible for ensuring compliance with the law?
Sarbanes-Oxley Act	A law to restore public trust by strengthening corporate accountability and tightening financial reporting requirements. It created the Public Company Accounting Oversight Board, an independent body that oversees public company audits. Includes provisions to protect whistleblowers, strengthen document retention, and criminalize fraud related to tampering with records or interfering with investigations.	Designed to protect investors and the public from fraudulent financial reporting by corporations. Created the Public Company Accounting Oversight Board, an independent regulatory body that oversees the audits of public companies.	Compliance is ultimately the legal responsibility of the CEO and CFO. However, actual day-to-day compliance can involve any or all of the following departments: • Chief Financial Officer • Chief Information Officer • Internal Audit Team • Compliance Officer • Legal Counsel

Law	Briefly describe the law.	Whose rights are covered by the law?	Who in an organization is responsible for ensuring compliance with the law?
Gramm-Leach-Bliley Act	This act repealed part of the Glass-Steagall Act, allowing banks and insurance companies to consolidate and created strict privacy and data protection rules for institutions that collect and manage consumers' personal financial data. The act was revised in 2023. This revision marked a shift from flexible “suggestions” to enforceable, prescriptive requirements. It’s now much clearer what institutions must actually do to comply.	Designed to protect consumers, specifically people who engage in financial transactions or receive financial products or services. This includes bank customers, insurance policyholders, credit card users, and anyone who shares personal financial data with a financial institution. The law protects anything that falls under the broad label of nonpublic personal information.	The act applies to financial institutions. This includes any business that collects and handles NPI in the course of offering financial products or services. It also places obligations on third-party service providers that financial institutions share data with. After the 2023 revision, every covered institution must now appoint a Qualified Individual to be responsible for overseeing and enforcing the information security program. Their duties include implementing the safeguards, managing incidents, and reporting annually to the board of directors or senior leadership.

Law	Briefly describe the law.	Whose rights are covered by the law?	Who in an organization is responsible for ensuring compliance with the law?
Health Insurance Portability and Accountability Act (HIPAA)	Originally enacted to help people keep their health insurance when changing jobs, its most lasting impact has been on healthcare data privacy and security. With the HIPAA Privacy Rule (2000) and Security Rule (2003), it became the primary U.S. law regulating the use, disclosure, and safeguarding of protected health information.	Protections are centered on individual patients and plan members. It sets boundaries on how health data is shared, even within an organization, to prevent unnecessary or harmful disclosures.	Compliance involves multiple roles in an organization. It requires the designation of a Privacy Officer and a Security Officer. The Privacy Officer oversees how PHI is handled and disclosed, while the Security Officer is responsible for implementing and maintaining the security safeguards for ePHI. Other key players include the IT team, compliance professionals, and anyone who interacts with health data, all of whom must be trained on HIPAA requirements.
USA Patriot Act	This law touches on a wide range of issues (immigration, banking, criminal procedures), it also had a major impact on digital surveillance, cybersecurity policy, and data access. At its core, the law made it easier for government agencies to collect, monitor, and analyze digital communications and electronic data.	In theory, the USA PATRIOT Act was designed to protect the rights and safety of U.S. citizens and residents by giving the government enhanced tools to detect and prevent terrorism. However, the Act reduced certain individual privacy rights, particularly in areas involving digital surveillance and due process.	Most of the compliance burden for the act falls on government agencies, especially law enforcement, intelligence agencies, and the judiciary, since they are the ones using the powers the act provides. There are some private-sector responsibilities, particularly in tech, telecom, and finance. For these, the chief compliance officer or general counsel typically oversees legal compliance and the chief information security officer is responsible for ensuring that data access and disclosure processes are secure, documented, and legally sound.

Law	Briefly describe the law.	Whose rights are covered by the law?	Who in an organization is responsible for ensuring compliance with the law?
Americans With Disabilities Act, Section 508	This section of the ADA requires federal agencies to ensure their electronic and information technology is accessible to individuals with disabilities. It was revised in 2017, This aligned the requirements more closely with the Web Content Accessibility Guidelines (WCAG) 2.0, Level AA.	Employees, contractors, and members of the public who interact with the agency’s digital content, services, or tools. It mandates any website, software, or digital platform created or used by a federal agency must meet specific criteria for accessibility—like keyboard navigability, screen reader compatibility, and clear labeling of images and buttons.	Section 508 applies to all federal agencies. This includes executive departments, independent agencies, and even parts of Congress that produce or procure EIT. It also applies to contractors and vendors providing digital services to the federal government; agencies must include 508 compliance requirements in their procurement contracts.